【 부록 1 】

정보보안점검 체크리스트

1. 정보보안 기본활동

연번	세부 점검사항	비고
1	기관 자체 실정에 맞는 정보보안업무 내규를 수립하고 있는가?	
2	매년 정보보안업무 활동계획을 수립・시행하는가?	
3	정보보안업무 전담 조직 및 직원(정보보안담당관)이 지정되어 있는가?	
4	소속 직원 근무성적 평가시 정보보안업무규정 준수여부를 반영하고 있는가?	
5	소속・산하기관 대상 정보보안 감사 또는 점검을 실시하는가?	
6	소속・산하기관 대상 정보보안 교육을 실시하고 있는가?	
7	사이버보안진단의 날을 내실 있게 수행하는가?	
8	정보보안 침해사고・규정위반 및 정보통신망 장애발생을 대비한 보고체계・조치절차가 마련되어 있는가?	
9	보직변경 등 인사이동시 정보시스템 접근권한을 신속하게 조정하는가?	
10	서버・PC 등 정보시스템 현황을 제대로 파악하는가?	
11	정보통신장비(노트북 등) 반출입 통제 및 현황 관리를 철저히 하는가?	
12	업무자료를 상용 정보통신서비스로 전송하고 있지 않는가?	
13	정보통신망 구축 및 유지보수를 수행하는 외부인력(보안관제인력 포함)에 대해 보안서약서 징구, 보안교육 등 충분한 보안조치를 하고 있는가?	
14	용역업체 직원의 내부 정보시스템 접근을 통제하고 있는가?	
15	홈페이지 등 외부 게시자료에 대한 정보공개 지침을 수립・반영하는가?	
16	중요 정보화사업에 대하여 보안성 검토절차를 이행하는가?	
17	정보보호시스템(상용 암호모듈 포함) 도입시 보안적합성 검증절차를 준수하는가?	
18	비밀을 전자적으로 처리할 경우 암호자재로 암호화하는 등 규정을 준수하는가?	

2. PC 및 서버 보안관리

연번	세부 점검사항	비고
1	PC・서버에 설치된 운영체제 및 응용프로그램을 최신 보안업데이트 하였는가?	
2	PC・서버의 불필요한 서비스를 검토하여 중단하고 정기적으로 인터넷에서 접속 가능여부를 확인하는가?	
3	백신이 자동 업데이트되고 실시간 감시기능이 설정되어 있는가?	
4	인터넷 PC에 업무관련 자료(비밀 포함)가 방치되어 있는가?	
5	P2P, 웹하드, 상용메신저 등 업무와 무관한 비인가 프로그램이 설치되어 있는가?	
6	비인가자 접근방지를 위해 CMOS・로그인 등 PC 비밀번호를 설정하였는가?	
7	서버내 저장자료는 중요도에 따라 접근권한이 설정되어 있는가?	
8	정보통신망 구성측면에서 PC 및 서버 등의 위치가 적정한가?	
9	비인가 휴대용 저장매체(USB, 외장형 하드디스크, 메모리카드 등) 사용기록이 존재하는가?	
10	전자우편은 발신지 IP의 국가명이 표시되고 해킹메일은 신고가 용이한가?	
11	비밀은 비밀용 USB를 별도 지정하여 사용하고 일반자료와 혼합 저장하지 않는가?	
12	정보보호시스템・서버・네트워크장비 등 로그기록을 1년 이상 유지・관리하는가?	
13	비인가 USB・정보통신기기 연결시 차단토록 보안 설정되어 있는가?	
14	PC・노트북 등 저장매체가 있는 기기 고장시 저장된 자료의 완전 삭제를 확인하고 외부에 수리를 의뢰하는가?	
15	「정보시스템 저장매체 불용처리지침」에 의거, 저장매체를 불용하였는가?	
16	모바일 업무는 행정업무와 현장업무를 구분하고 별도의 단말기를 운영하는가?	
17	불필요한 원격접속 S/W는 비활성화 또는 제거하였는가?	
18	상주 용역업체 네트워크와 직원용 네트워크를 분리하였는가?	
19	네트워크 접근제어를 위한 보안정책을 적절하게 설정하였는가?	
20	네트워크 접근제어 정책에 대한 생성일・목적・요청자 등 이력을 관리하는가?	
21	주요 정보보호시스템의 보안정책 설정파일을 주기적으로 백업하고 있는가?	

3. 네트워크 보안관리

연번	세부 점검사항	비고
1	정보시스템 세부 구성도(IP 포함)를 최신으로 유지하는가?	
2	업무자료를 소통하기 위한 내부망은 인터넷과 분리 운영하는가?	
3	인터넷·업무망간 자료공유 방안이 적절한가?	
4	업무자료를 소통하기 위한 내부망 구축시 사설주소체계(NAT)를 적용하는가?	
5	국가정보원장이 안정성을 검증한 정보보호시스템을 운용하고 있는가?	
6	인가받지 않은 단말기가 네트워크에 연결하지 못하도록 조치하고 있는가?	
7	네트워크를 통한 파일공유를 제한하고 필요시 보안대책을 세우고 있는가?	
8	장비 신규도입 등 전산망 구성 변동시 관련사항을 기록하는가?	
9	비인가 무선인터넷·무선랜 등 허가받지 않은 인터넷 접속경로가 존재하는가?	
10	첨단 정보통신기기(IoT 등)에 의한 내부 업무자료 유출 가능성이 존재하는가?	
11	시스템 최초 설치시 등록된 초기 계정·패스워드를 변경하였는가?	
12	네트워크 장비·정보보호시스템·서버는 비인가자가 접속하지 못하도록 IP 통제 등 보안설정하고 불필요한 서비스포트를 제거하는가?	
13	네트워크 장비·정보보호시스템·서버 등의 관리자 네트워크를 인터넷·업무망과 별도로 분리하여 운용하고 있는가?	
14	무선네트워크 구축시 사전에 보안성 검토를 수행하고 보안대책을 준수하는가?	
15	정보시스템에 대한 보안취약점을 주기적으로 점검하는가?	
16	소프트웨어개발보안(시큐어코딩)을 적용하여 개발하였는가?	
17	원격지 개발시 개발장소를 점검하고 있는가?	
18	원격 유지보수를 금지하고 비인가 원격접속을 차단하는가?	
19	직원의 재택·파견·이동근무 등 원격근무시 보안관리 대책이 적절한가?	
20	음란·도박 등 유해사이트를 차단하고 사이트목록을 주기적으로 갱신하는가?	
21	해외에 위치한 사무소와 인원에 대해 보안대책을 지원하고 주기적으로 점검하는가?	
22	인터넷전화 제품은 TTA Verified Ver 4. 이상을 사용하는가?	
23	인터넷전화는 인터넷망에 설치된 경우 물리적으로 분리하고, 업무망에 설치된 경우 물리적 또는 논리적(VLAN)으로 분리하였는가?	
24	서버가 위치한 네트워크는 방화벽 등으로 사용자 네트워크와 분리하고 있는가?	

4. 정보통신시설 보안관리

연번	세부 점검사항	비고
1	인위적·자연적 원인에 의한 정보통신망 장애 대비 백업 등 재난방지 대책을 강구하였는가?	
2	통합전산센터, 정보통신실 등 중요 정보통신시설을 보호구역으로 관리하는가?	
3	사무실 책상서랍 등에 비밀문건이나 비인가 정보통신기기가 방치 여부를 주기적으로 확인하는가?	
4	외부인의 정보통신실 출입을 통제하고 기록을 유지하는가?	
5	무정전 전원공급장치 등 비상시 전력장애 대책을 강구하였는가?	
6	침입경보장치, CCTV 등 보안장비와 방화장비(하론소화기 등) 정상동작 여부를 정기적으로 점검하고 있는가?	
7	정보통신시설에 비상시 긴급 파기를 위한 장비(해머 등)를 비치하고 있는가?	
8	정보통신시설에 대한 접근권한을 업무목적에 따라 차등 적용하고 있는가?	
9	정보통신장비 수리·점검시 정보보안담당관 또는 분임정보보안담당관 입회하에 진행하는가?	
10	민간 클라우드 컴퓨팅서비스 사용시 보안인증을 받은 서비스를 이용하는가?	
11	계약서에 정보통신망 구성도, IP주소현황 등 누출금지정보를 명시하고 있는가?	
12	시각동기화를 통하여 정보시스템 시각을 정확히 유지하고 있는가?	
13	CCTV 등 단독망 형태의 시스템을 인터넷망과 혼용하지 않고 분리·운영하는가?	

5. 암호자재 및 암호알고리즘 관리

연번	세부 점검사항	비고
1	비밀을 소통・보호하기 위하여 국가정보원장이 개발하거나 안전성을 확인한 암호자재를 사용하는가?	
2	국가정보원장이 승인하지 아니한 암호자재 또는 외국에서 생산된 암호기능 탑재 시스템을 무단으로 사용하는가?	
3	암호자재를 취급하는 인원을 암호자재 취급자로 지정・관리하는가?	
4	암호자재 취급인가자 중 암호자재 배부 또는 반납하는 직원에 대해 인감등록을 실시하는가?	
5	각 암호자재에 대한 운용관리 정・부책임자 및 실무 담당자를 지정하였는가?	
6	암호자재 설치, 운영, 보관에 대한 보안대책이 수립되었으며 이행되고 있는가?	
7	암호자재를 복제・복사하거나 또는 국가정보원장이 승인 없이 암호자재를 해외 제공・반출한 사례는 없는가?	
8	암호자재 관련 문서를 비밀로 생산하여 관리하고 있는가?	
9	사용중인 암호자재의 사용목적 및 보호대상 변경 시, 국가정보원장에게 승인을 받았는가?	
10	노후 등으로 사용하지 않거나 또는 도입 후 6개월 이내에 설치하지 않는(미래용・예비용 암호자재 제외) 등 보관만 하고 있는 암호자재가 있는가?	
11	'암호자재 관리기록부', '암호자재 점검기록부', '지편자재 사용기록부' 등을 누락하지 않고 작성・유지하고 있는가?	
12	암호자재 책임자는 주1회 이상 암호자재를 점검하여 그 결과를 '암호자재 점검기록부'에 기록・유지하고, 보안담당관은 점검사항을 월 1회 확인하고 있는가?	
13	암호자재 배부・반납 등의 업무는 암호자재 취급자가 직접 수행하고, '암호자재 증명서'를 작성・보관하고 있는가?	
14	암호자재의 정・부 책임자 및 실무 담당자 교체시 인계인수를 실시하고 '암호자재 관리기록부'에 인계인수 사항을 기록하는가?	

6. 보안관제 등 해킹 대응활동

연번	세부 점검사항	비고
1	사이버공격에 대응하기 위해 자체 관제센터를 운영(직접 혹은 보안관제 전문업체 용역)하거나 다른 국가・공공기관에 위탁 하였는가?	
2	보안관제센터 운영을 총괄 관리하는 전담 공무원이 있는가?	
3	사이버공격 탐지・대응 및 자체 DDoS공격 대응매뉴얼 등이 구비되어 있는가?	
4	해킹사고 조사결과, 보안 위규자에 대한 처벌이 자체 규정・지침 등에 명시되어 있고 실제로 이루어지고 있는가?	
5	국가사이버안전센터・부문보안관제센터 등 유관기관과 보안관제시스템을 연계 운영하는가?	
6	자체 사이버위기 대응 모의훈련을 주기적으로 실시하는가?	
7	홈페이지 해킹, DDoS공격, 해킹메일 수신 등 침해사고 발생시 국가정보원・여성가족부 등 유관기관에 즉시 신고하는가?	
8	시스템 장애시 유지보수 업체 및 긴급연락체계가 최신화 되어 있는가?	
9	보안관제시스템에 대한 물리적・관리적・기술적인 보안대책을 준수하고 있는가?	
10	침해사고 발생시 사고조사내역을 작성하고 해당내용을 기관장에 보고하는가?	
11	전직원을 대상으로 해킹메일 대응방안 및 침해사고 대응절차 등 관련 교육을 수행하는가?	
12	보안취약점 발표시 산하기관 또는 담당직원과 즉시 공유하는가?	
13	국가사이버안전센터 등과 사이버위협정보, 탐지기술 등 정보를 공유하고 있는가?	
14	사이버공격 발생시 소속・산하기관에 전파할 수 있는 체계가 구비되었는가?	
15	국가사이버안전센터에서 제공한 탐지규칙정보에 대한 보안관리 및 전담관리자를 지정・운영하고 있는가?	
16	침해사고 발생시 해당 시스템을 무단 포맷할 경우 보안위규(사고조사 방해) 행위임을 시스템 관리자・사용자가 인지하고 있는가?	